

Risk & Compliance

The adversarial model, the audit posture, and the regulatory perimeter

RoundFi

2026-06-23

CONTENTS

1. The posture
2. Adversarial model
3. Risk review
4. Regulatory considerations
5. Residual-risk register — the honest bottom line

Derived document. This is a derivation of [docs/spec/MASTER-SPEC.md](#) (§9 Adversarial model, §10 Risk review, §13 Regulatory considerations). The Master Spec is the single source of truth; if a number here disagrees with it, the Master Spec wins. Every constant, SEV id, and checklist item is pinned to the deployed Jun 2026 source and the cited operations docs.

1. The posture

RoundFi makes two honest claims about its own risk. **First**, the on-chain protocol has been driven through multiple internal and external audit cycles and the substantive findings are closed in code. **Second**, the protocol's largest **unmitigated** risks are not in the Rust — they are in the adversarial economics that a simulator has not yet quantified, in deploy-time configuration that must be set correctly on the mainnet path, and in the regulatory model, which is resolved by counsel rather than code.

This document is written for risk reviewers, auditors, and compliance/legal. It keeps the Master Spec's tone deliberately: **the residual gaps are named, not buried**. A reviewer should be able to use the tables below as a checklist of what is closed, what is in flight, and what is explicitly an open question — and find nothing material omitted to make the posture look better than it is.

The three surfaces, in order:

1. **Adversarial model** (§2) — a motivated attacker manufacturing reputation or extracting value.
2. **Risk review** (§3) — what the audit cycles closed, and the deploy-time gates still ahead.
3. **Regulatory perimeter** (§4) — LGPD, irregular fund collection, cross-border.

2. Adversarial model

The protocol is designed against a **motivated attacker** trying to manufacture reputation or extract value — not against accidental misuse. The product being defended is the **reputation**, so the attacks that matter most are the ones that would let an adversary mint a credit signal they did not earn, or dump a loss on an honest counterparty. The full treatment is `docs/spec/adversarial-model.md` (planned); what follows reproduces the Master Spec §9 attack/defense/residual table and explains each row.

2.1 The attack surface

Attack	Vector	Current defense	Residual gap
Score farming	Parallel 1-member pools, +10 each in parallel	Completed-pools floor (<code>cycles_completed</code>) + 30-day <code>P00L_COMPLETE</code> cooldown — score alone can't promote	L4-provisional gate is score+cycles; metric-based Elite (off-chain) not yet on-chain
Sybil	N wallets, one operator, coordinated pools	Each wallet must independently accrue completed pools over wall-clock time; reputation is per-wallet, non-transferable	Cost/benefit table to be quantified by the simulator (Pass 8)
Cartel	Closed group farms each other's reputation	Same wall-clock floor; no special weight for closed groups (a closed cartel earns the same trajectory as honest strangers)	Whether cartel-earned reputation should be <i>discounted</i> is an open product question
Elite farming	Reach L4 cheaply to exploit the 3% stake	8 completed pools (~4y honest history) + identity hard floor (PoP) — Elite is the most-defended tier	—
Escape-valve abuse	Seller exits a slot about to default, dumps the loss on a naïve buyer	Buyer inherits <code>escrow_balance</code> (the funds at risk are already locked against the slot); commit-reveal prevents price-sniping	Buyer-side UX must surface the inherited obligations clearly
Goodhart	Optimize the promotion metric without the behavior it proxies	Promotion is gated on <i>consequential</i> on-chain events (real USDC at stake), not a soft signal — gaming the metric requires actually keeping obligations	The off-chain metric weights (v1.5) must be designed Goodhart-aware

Source: MASTER-SPEC §9.

2.2 Reading the rows

Score farming. Score is farmable on its own — an operator spins up parallel one-member pools and harvests +10 / +50 increments. The defense is that score is **necessary but never sufficient**: promotion is doubly-gated, and the second gate (`cycles_completed`) only advances on a `P00L_COMPLETE` attestation carrying a 30-day per-subject cooldown. A farm can buy points; it cannot buy the wall-clock time. **Residual:** the on-chain L4 gate is v1-provisional (score + cycles);

the proposal's metric-based Elite criteria live off-chain and have not yet hardened the on-chain gate.

Sybil. Splitting into N wallets does not help, because reputation is **per-wallet and non-transferable** — each wallet must independently accrue completed pools over wall-clock time. There is no pooling of reputation across an operator's wallets. **Residual:** the precise cost/benefit of a sybil campaign is **not yet quantified**; that is the simulator's job (Pass 8).

Cartel. A closed group that farms each other's reputation hits the **same** wall-clock floor as everyone else — there is no special weight for closed groups, so a cartel earns exactly the trajectory honest strangers would. **Residual:** whether cartel-earned reputation should be **discounted** relative to open-participation reputation is an **open product question**, not a settled defense.

Elite farming. Reaching L4 to exploit the 3% stake is the most-defended path: **8 completed pools** (roughly a multi-year honest history) **plus** the identity hard floor (proof-of-personhood). The Master Spec records **no residual gap** on this row — it is the one attack the current design considers fully walled.

Escape-valve abuse. A seller could try to exit a slot about to default and dump the loss on a naïve buyer. The defense is structural: the buyer inherits the slot's `escrow_balance`, so **the funds at risk are already locked against the slot** the buyer is acquiring — the seller cannot strip the collateral on the way out. The commit-reveal listing path (anti-MEV) additionally prevents price-sniping. **Residual:** this is a **UX** gap, not a protocol one — the buyer-side interface must surface the inherited obligations clearly so the buyer prices them.

Goodhart. The general risk that optimizing a metric diverges from the behavior it proxies. RoundFi's structural answer is that promotion is gated on **consequential** on-chain events — real USDC at stake — not a soft signal, so gaming the metric requires **actually keeping obligations**. **Residual:** the off-chain metric weights (v1.5) must themselves be designed **Goodhart-aware** once Commitment and Recovery are calibrated.

2.3 The most important open work

Per the partner review, and the team agrees: **the single most important open item is to quantify the sybil/cartel cost-benefit with a simulator** (10k virtual users, 12–36 month horizon) and publish the adversarial economics. The honest framing is that the protocol today rests on structural arguments ("reputation is per-wallet and time-gated, so manufacturing it is expensive") that have **not yet been turned into numbers**. For every grant and partner conversation, *"we observed risk reduction"* beats *"we believe reputation reduces risk."* Until the simulator ships, the sybil and cartel rows carry genuine, acknowledged residual uncertainty.

3. Risk review

The protocol has been through multiple internal and external audit cycles (Adevar Labs SEV series; the Caio HIGH/MEDIUM reviews). State as of 2026-06-12.

3.1 Closed in code — the SEV series

The substantive findings are **resolved in handler logic**, not merely tracked. The Master Spec §10 enumerates them:

Finding(s)	Area closed
SEV-002	Grace leak
SEV-005 / SEV-038	Cycle / orphan guards
SEV-013	Commit-reveal salt
SEV-016 / 029 / 034	Escrow vesting math
SEV-024	Fee timelock
SEV-027	Admin-attest cooldown
SEV-031	Pool viability (<code>PoolNotViable</code> guard)
SEV-047	Identity gate

Source: MASTER-SPEC §10. Alongside the SEV series, two design-level corrections are closed: **Pass-3** (claim $\neq$ cycle-complete — receiving the carta is score-neutral and does not advance `cycles_completed`) and the **L4 identity hard floor** (Elite always requires `identity_verified`, independent of the configurable gate). These are the findings a code auditor would expect to see retired; they are.

3.2 The mainnet checklist — config and deploy-time, not handler logic

A separate class of risk is **not** a code defect but a **deploy-time configuration** that must be set correctly before mainnet. These are gates on the mainnet path, tracked in `docs/operations/mainnet-canary-plan.md`:

Gate	What it sets
<code>IdentityGateConfig.required_min_level = 3</code>	L2/L3 become verified-only on mainnet (devnet 0)
<code>reputation_program != Pubkey::default()</code> in <code>initialize_protocol</code>	Reputation program wired, not a zero address
Treasury + upgrade authority on a Squads 3-of-5 multi-sig	No single key controls funds or upgrades
External audit clear (#267)	Independent sign-off
Legal counsel (#268)	Regulatory clearance (see §4)

Source: MASTER-SPEC §10. The important distinction for an auditor: a clean code review does **not** discharge these items. The protocol can be correct and still unsafe to launch if, for example, the identity gate is left at the devnet-open 0 or the upgrade authority sits on a single key. The

checklist is the bridge between "the handlers are right" and "this is safe to deploy with real users' money."

3.3 The default-settlement caveat (deployed-state honesty)

Seven of the eight protocol capability areas were exercised end-to-end on devnet on 2026-06-12 with real USDC; **default settlement (`settle_default`) is armed and time-gated, not yet replayed** to completion — it waits on the grace window elapsing (MASTER-SPEC §11, capability #9: "armed; grace-gated"). The seizure order and the guard are in code and audited, but the live default-recovery path is the one capability whose end-to-end execution is still pending. A risk reviewer should treat the solvency-under-default claim as **armed and audited but not yet field-replayed** — consistent with how the Master Spec marks it.

3.4 Non-code risk

The Master Spec is explicit that **regulatory risk is not addressed in Rust**: LGPD, Bacen, and irregular-fund-collection exposure are "addressed by counsel, not Rust," and constitute **a hard gate on mainnet**. This is the handoff point to §4.

4. Regulatory considerations

RoundFi's **primary regulatory surface is the model, not the code**. The protocol is engineered to be **legible** to a regulator — every event is on-chain, attestations are auditable, and the reputation derivation is documented in the Master Spec — which is itself a compliance asset. But legibility is not clearance. The open questions below all require **specialist counsel, not engineering**, and are hard gates on the mainnet path (`docs/operations/mainnet-canary-plan.md` § 3.1, #268).

4.1 LGPD — Brazilian data protection

Reputation is **personal data**. A portable, on-chain credit signal derived from an individual's financial behavior falls within the LGPD perimeter, which means **portability, consent, and the right-to-explanation** apply. The same property that makes the system legible to a regulator — durable, immutable on-chain attestations keyed to a wallet — creates the LGPD obligation: the data subject has rights over that record. This is a tension to be resolved by counsel, not a feature to be engineered away; it is named here so a compliance reviewer sees it addressed.

4.2 Captação irregular — irregular fund collection (Bacen / CVM)

A **pooled-savings instrument** touches Bacen / CVM perimeters depending on its structure — the risk that the pool is characterized as **irregular fund collection** or an unregistered security. RoundFi's deliberate de-risking choices on the mainnet path are structural:

- **The size-1 canary** — the mainnet canary is a **self-pool of one member** with real USDC (MASTER-SPEC §11 / §12). A one-member pool collects no funds from the public, which keeps the canary outside the captação-irregular perimeter while the protocol is exercised on mainnet.

- **The consortium framing** — positioning the instrument as a *consórcio*, the established and regulated Brazilian rotating-credit structure, rather than as a novel deposit-taking product.

Both are **deliberate** choices to keep the early mainnet footprint inside a defensible regulatory posture; neither is a final clearance, which counsel owns.

4.3 Cross-border

If **non-BR users participate**, the protocol picks up **US exposure** — CFTC and state money-transmission perimeters. The Brazilian framing (*consórcio*, LGPD) does not extend to US participants, so the cross-border case is a distinct regulatory question that widens with the user base. It is named in the Master Spec §13 as an open exposure, not a solved one.

4.4 The compliance summary

Surface	Perimeter	RoundFi posture	Owner
LGPD	BR data protection	On-chain attestations = personal data; rights apply	Counsel
Captação irregular	Bacen / CVM	Size-1 canary + consortium framing as de-risking	Counsel
Cross-border	US CFTC / money-transmit	Exposure if non-BR users participate	Counsel

All three are **hard gates on the mainnet path** (#268). The protocol's job is to remain auditable and legible; the clearance itself is legal work, and the Master Spec does not pretend otherwise.

5. Residual-risk register — the honest bottom line

Pulling the three surfaces together, the material **residual** risks — the items not yet closed — are:

Residual risk	Surface	State
Sybil / cartel economics unquantified	Adversarial	Open — simulator (Pass 8) pending
Metric-based Elite gate not yet on-chain	Adversarial	Open — v1.5 oracle; gate is score+cycles
Cartel-reputation discount undecided	Adversarial	Open product question
Escape-valve inherited-obligation UX	Adversarial	Open — buyer-side UX work
<code>settle_default</code> not yet field-replayed	Risk review	Armed, audited, grace-gated
Mainnet config gates (identity, multi-sig, etc.)	Risk review	Deploy-time; tracked, not yet executed
LGPD / captação / cross-border clearance	Regulatory	Hard gates; counsel-owned (#268)

None of these is hidden in the body of this document; the register simply collects them. The protocol's defensible claim is **"the on-chain findings are closed in code, and the remaining risks are named, gated, and assigned"** — which is a stronger and more credible position for an

auditor or grant reviewer than a clean bill of health that ignores the economics and the regulatory perimeter.

Cross-references: the reputation walls these attacks target → [04-behavioral-reputation-score](#) ; the solvency model behind the escape-valve and default rows → [05-stress-lab-economic-model](#) ; protocol mechanics → [02-technical-whitepaper](#) . Full adversarial, audit, and regulatory detail live in MASTER-SPEC §9, §10, and §13.